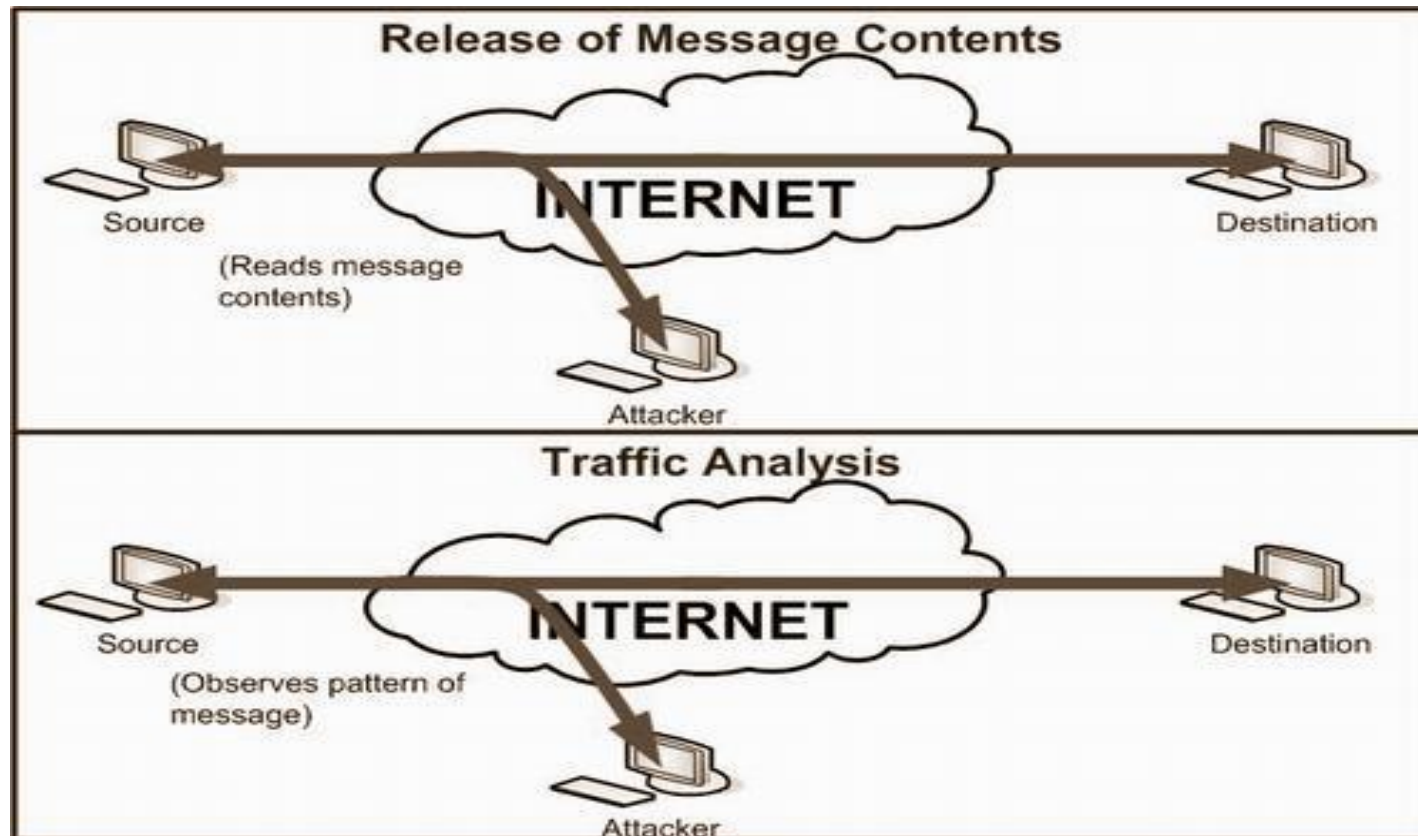


General Categories of Security Attacks

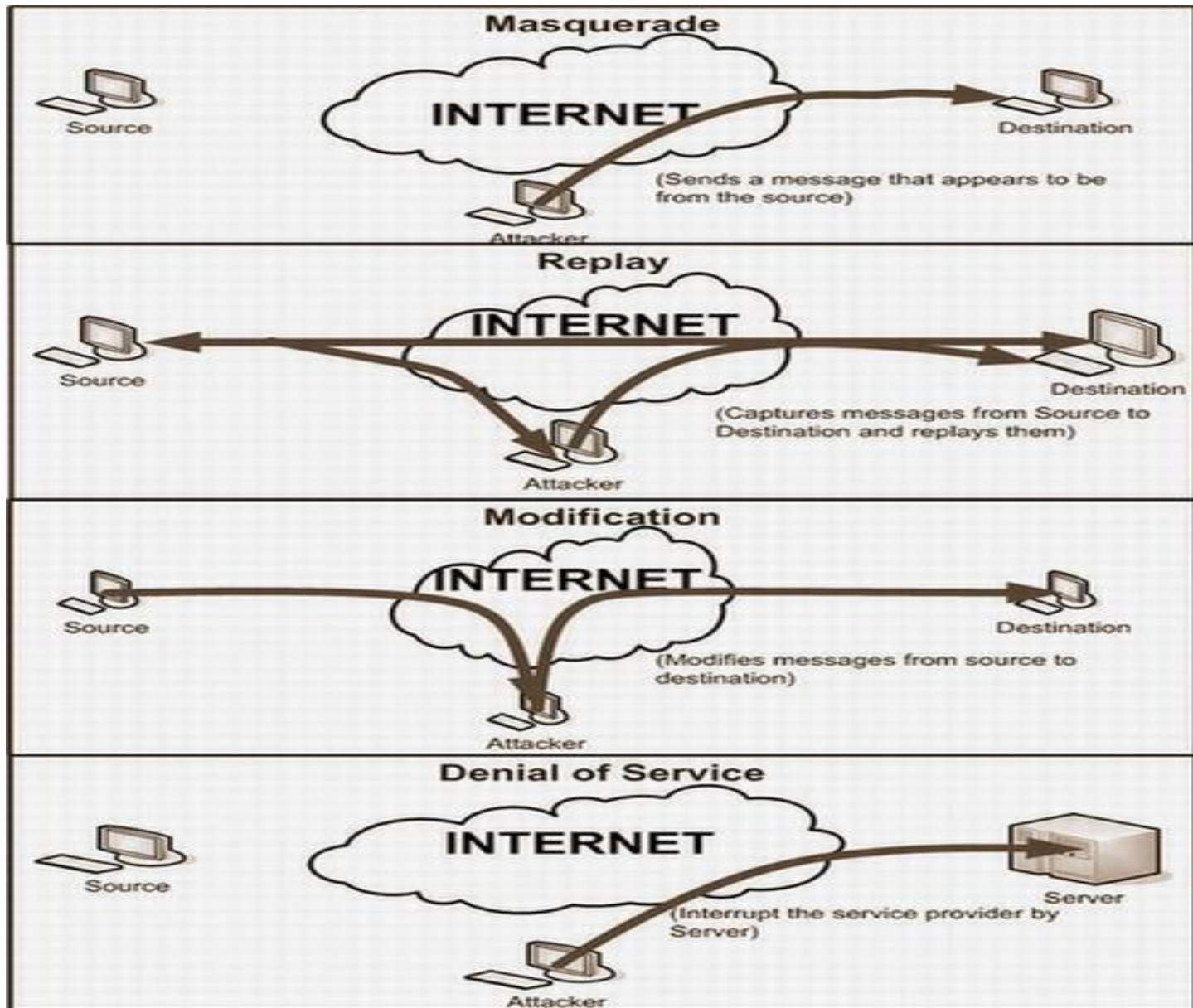
- Attacks can be categorized into following basic categories:
 - Interruption (attack on availability)
 - Interception(attack on confidentiality)
 - Modification (attack on integrity)
 - Fabrication (attack on authenticity)

- We can further classify security attacks as *passive attacks* and *active attacks*.
- **Passive attacks** are only involved in monitoring of the information(interception). The goal of this attack is to obtain transmitted information.

- Two types of passive attacks are
 - *release of message content*
 - *traffic analysis*



- Active attacks are involved in modification of data (interception, modification, fabrication) or creation of false data.
- These attacks are further subdivided into four categories:
 - *Masquerade*
 - *Replay*
 - *modification of data*
 - *denial of service*



Reconnaissance Attacks

- Gathering information against a targeted host or network is called reconnaissance attack.
- Attackers analyze the target host and try to discover the details:
 - alive IP addresses
 - open ports of the network
 - failure of operating system
 - types of services and protocols running

- Some basic reconnaissance attacks are:
 - Packet Sniffers
 - Port scan and ping sweep
 - Internet information queries

Packet Sniffers

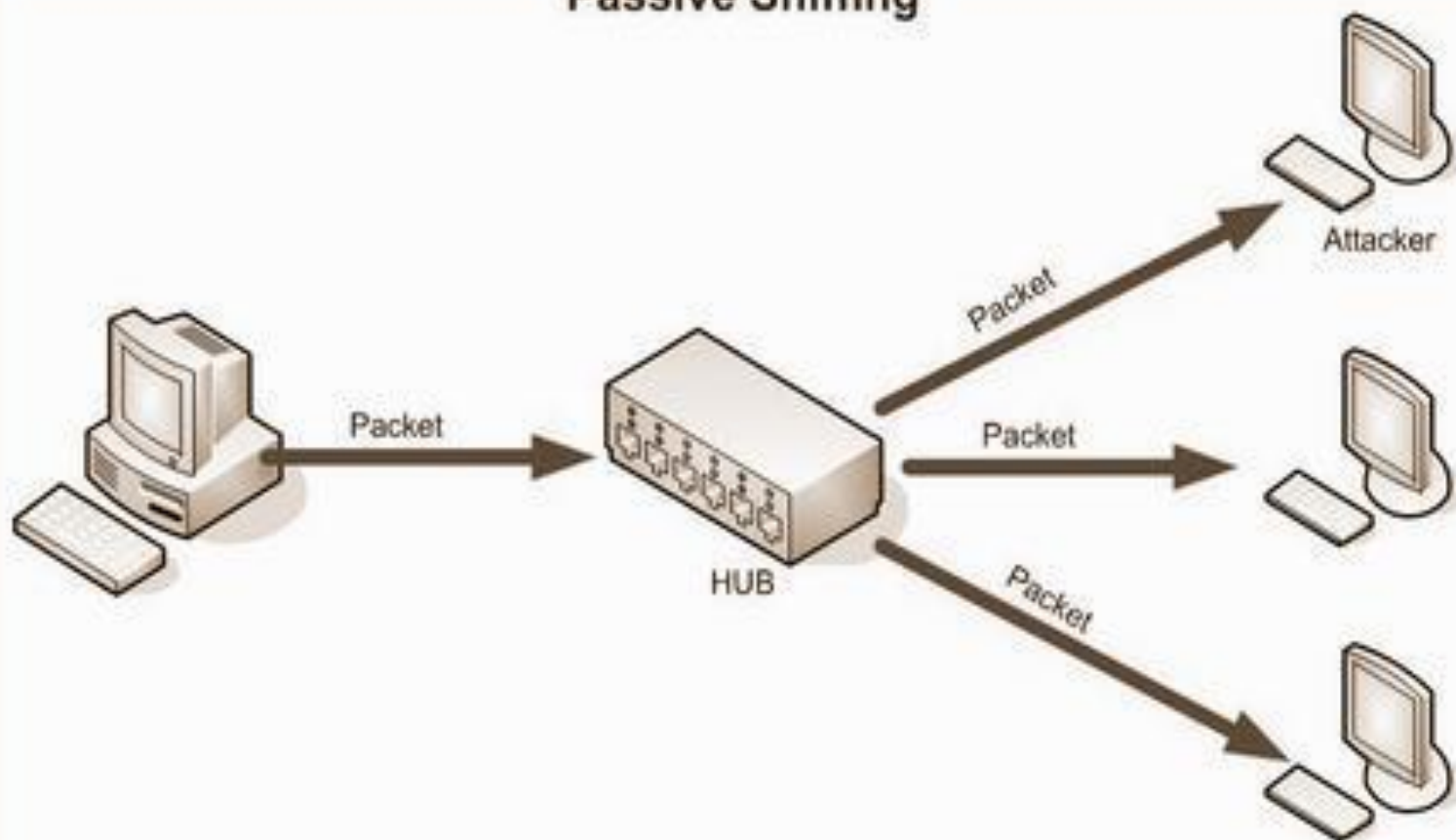
- Packet sniffer is a tool or device that can be used for capturing the packet at data link layer.
- Can be used both by the hacker for eavesdropping and by the administrators for network monitoring and troubleshooting
- *Tcpdump*, *windump*, *wireshark* are examples of different sniffing tools.

- Sniffing can be of two types depending on the network.
 - Passive Sniffing
 - Active Sniffing

Passive Sniffing

- Passive sniffing is used in hubbed networks.
- hard to detect because it generates no traffic on network.
- To avoid passive sniffing most of the networks nowadays are using switches instead of hubs.

Passive Sniffing



Active Sniffing

- Active sniffing is performed on switched network
- Switch worked as a central entity, rather than broadcasting
- Switches worked on the basis of MAC addresses.

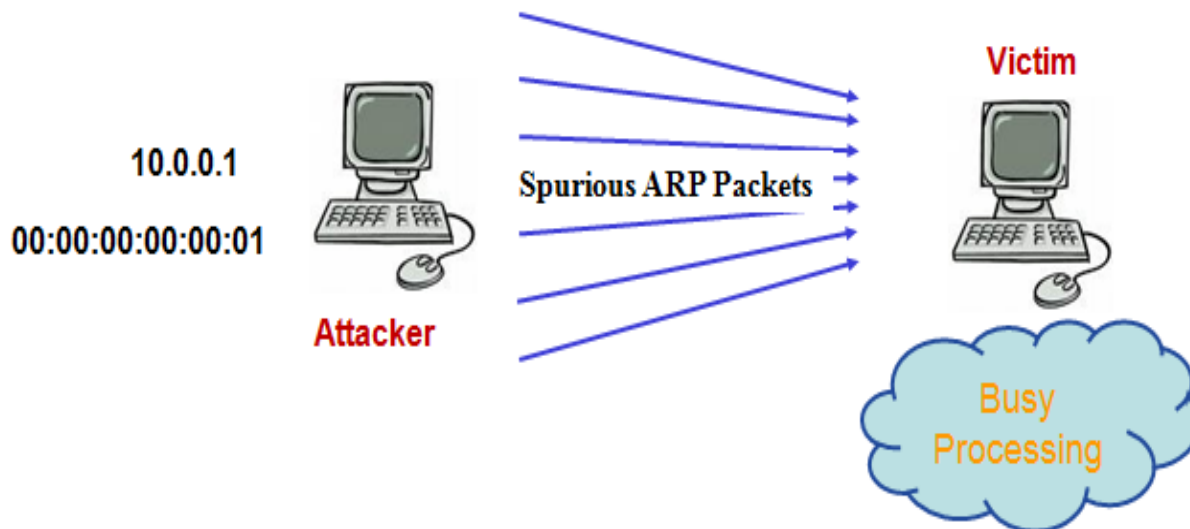
- They maintain an address resolution protocol (ARP) table in a special type of memory called Content Addressable Memory (CAM).
- ARP table has all the information that which IP address is mapped to which MAC address.

- Two major attacks are possible:
 - MAC Flooding
 - ARP poisoning

MAC Flooding

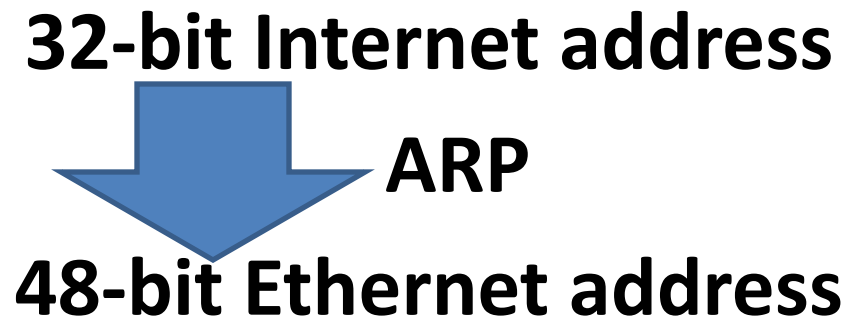
- The switch can intelligently route packets from one host to another.
- The switch has limited memory
- The act of overloading the CAM is known as MAC flooding.
- MAC flooding bombard the switch with fake MAC addresses, so that it became saturated

- The switch goes to a *failopen* mode and cannot perform IP to MAC mappings
- It starts behaving like a hub and starts transmitting the data to all machines.



What is ARP?

- Address Resolution Protocol maps IP address to MAC address
- Purpose of ARP



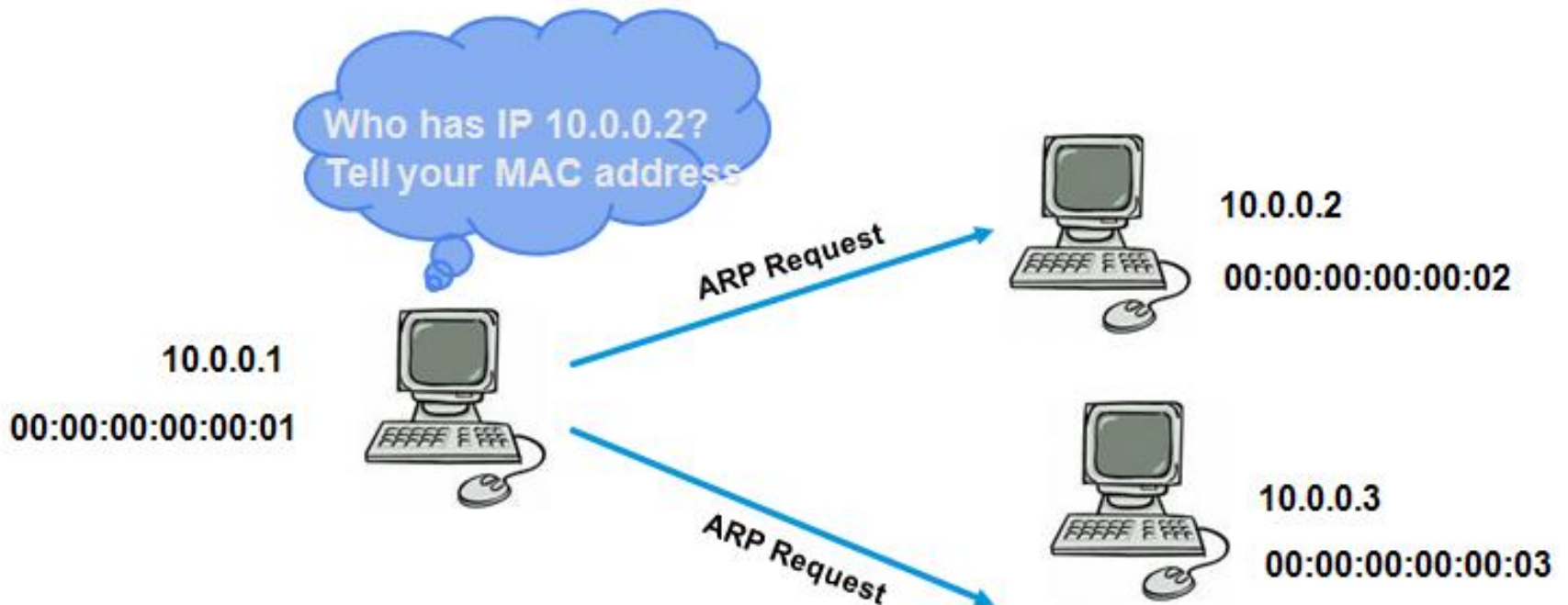
- ARP CACHE : IP – MAC Bindings

IP	MAC	TYPE
10.0.0.2	00:00:00:00:00:02	dynamic

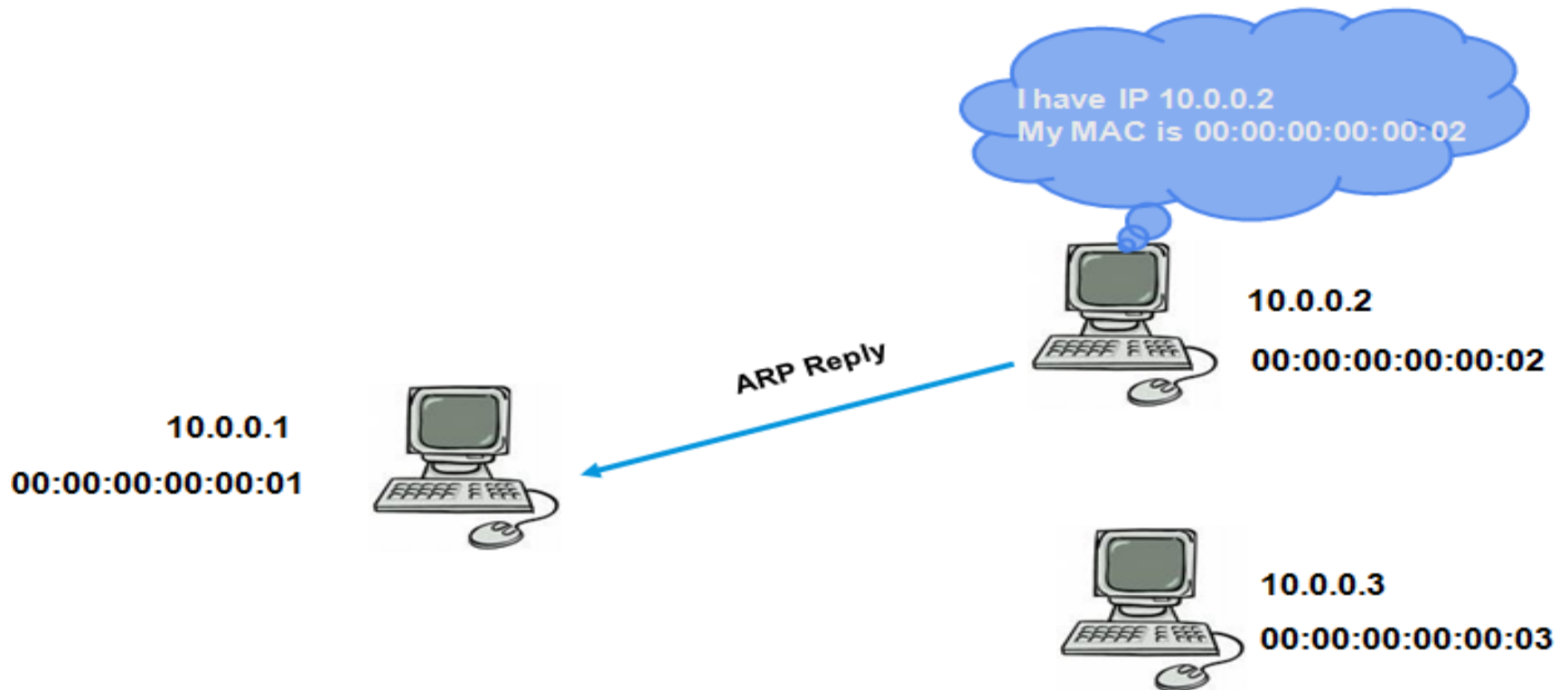
How ARP Works?

- ARP resolves IP addresses to MAC addresses.
- ARP works by **broadcasting** requests and caching responses for future use
- The ARP table is updated whenever an ARP response is received
- Requests are not tracked
- ARP announcements are not authenticated

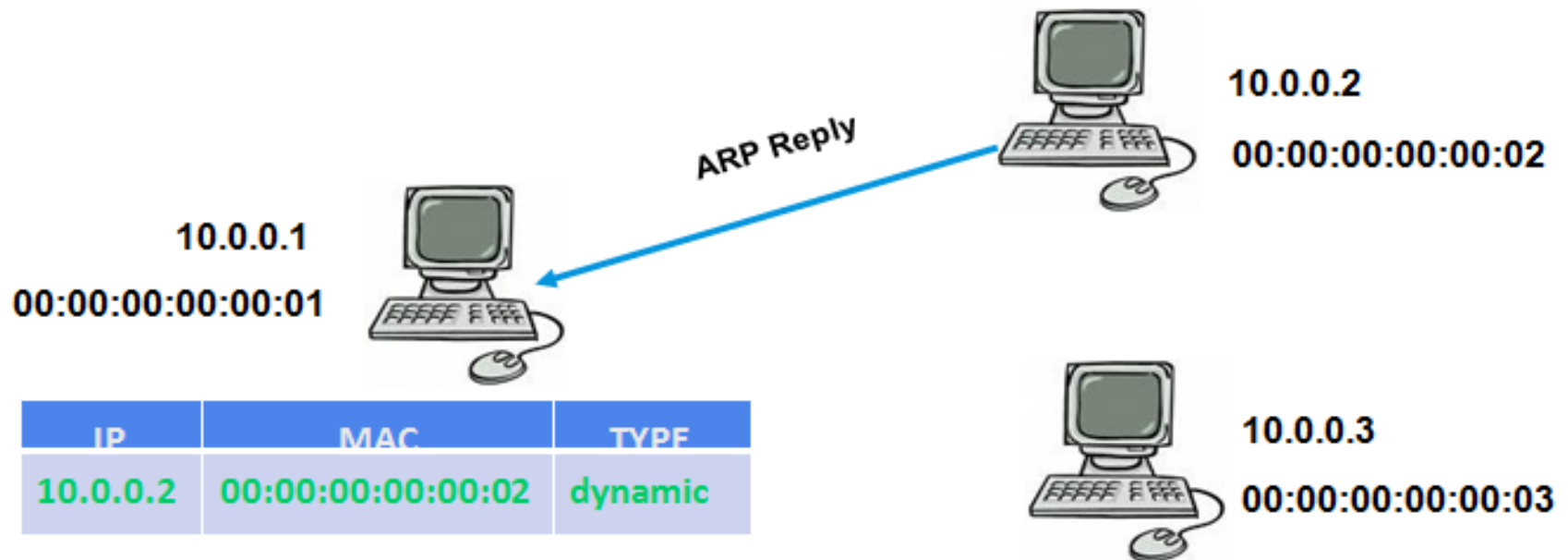
- ARP Request is Broadcast to all the hosts in LAN



- Unicast Reply from concerned host



- ARP cache : updated



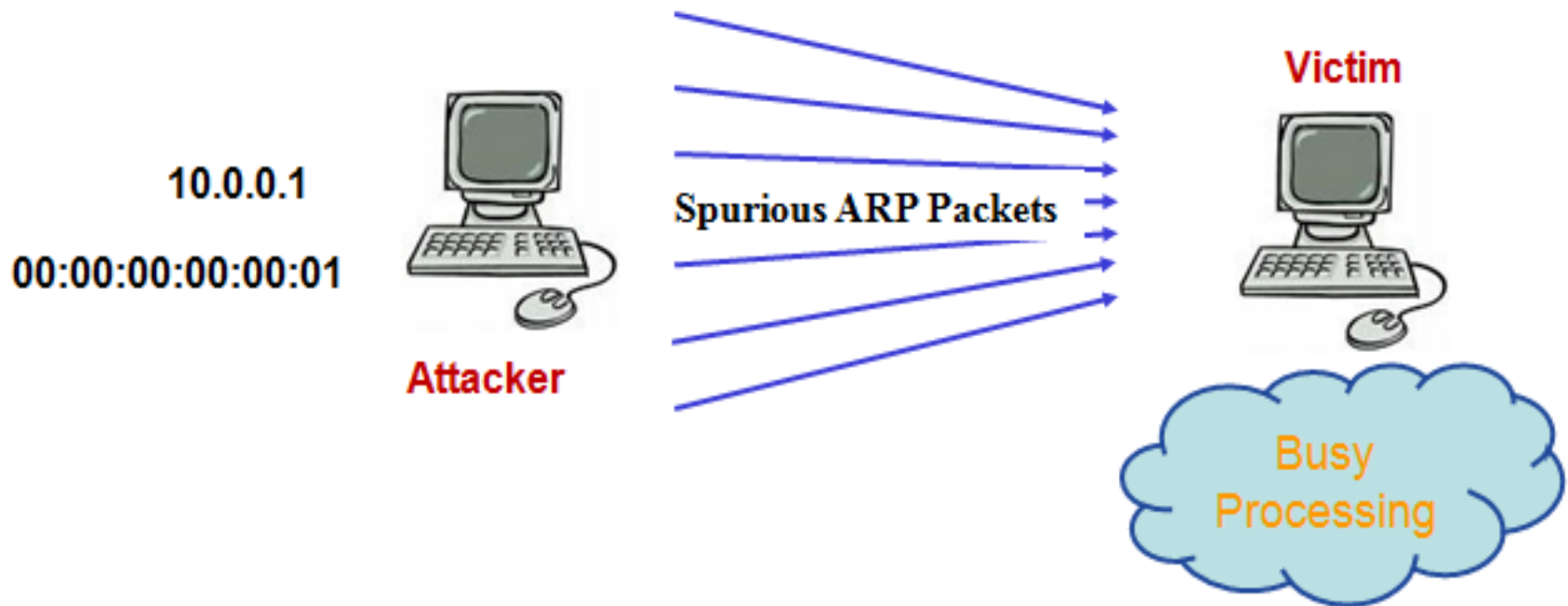
- Machines trust each other, a rogue machine can spoof other machines
- An ARP cache updates every time that it receives an ARP reply, even if it did not send any ARP request
- It is possible to **poison** an ARP cache by sending **fake ARP replies**

- ARP Vulnerable:
 - ARP is a stateless protocol
 - Hosts cache all ARP replies sent to them even if they had not sent an explicit ARP request for it.
 - No mechanism to authenticate their peer

- MAC Flooding Degrades Network Performance
- Attacker bombards the switch with numerous forged ARP packets at an extremely rapid rate such that its CAM table overflows

DoS by Spurious ARP Packets

- Attacker sends numerous spurious ARP packets at the victim such that it gets engaged in processing these packets
- Makes the Victim busy and might lead to Denial of Service



Port Scan and Ping Sweep

- These are two common network probes typically used to run various test against a host or device to find vulnerable services.
- They are helpful to examine the IP address and the services running on a device or host.

- The most popular probing tool is **Nmap** (Network Mapper)
- Different types of Nmap scans are
 - ***TCP Connect Scan***
 - ***TCP SYN Scan***
 - ***FIN Scan***
 - ***ACK Scan***

- The method of finding that which IP addresses are alive is called **ping sweep**.
- Attacker sends an ICMP packet to each machine (with in a range) to a targeted network.
- ICMP replies from different machines are logged into a file for future reference

Internet Information Queries

- Consists of:
 - DNS queries
 - IP queries
 - Ping sweep
- After these queries, port scan is started by the hacker
 - to find out which ports are open and which services are running on these ports.

Access Attack

- **Access attacks** occur when a malicious hacker exploit **vulnerabilities** and succeed to access the confidential information of any organization.
- Different types of attacks are:
 - Password Attacks
 - Trust Exploitation
 - Port Redirection
 - Man-in-the-middle attack

Password Attack

- Repeated attempts to find the user information (user name or password)
- Types of Password Attack are:
 - Dictionary Attack
 - Brute force attack
 - Hybrid Attack

Types of password Attacks

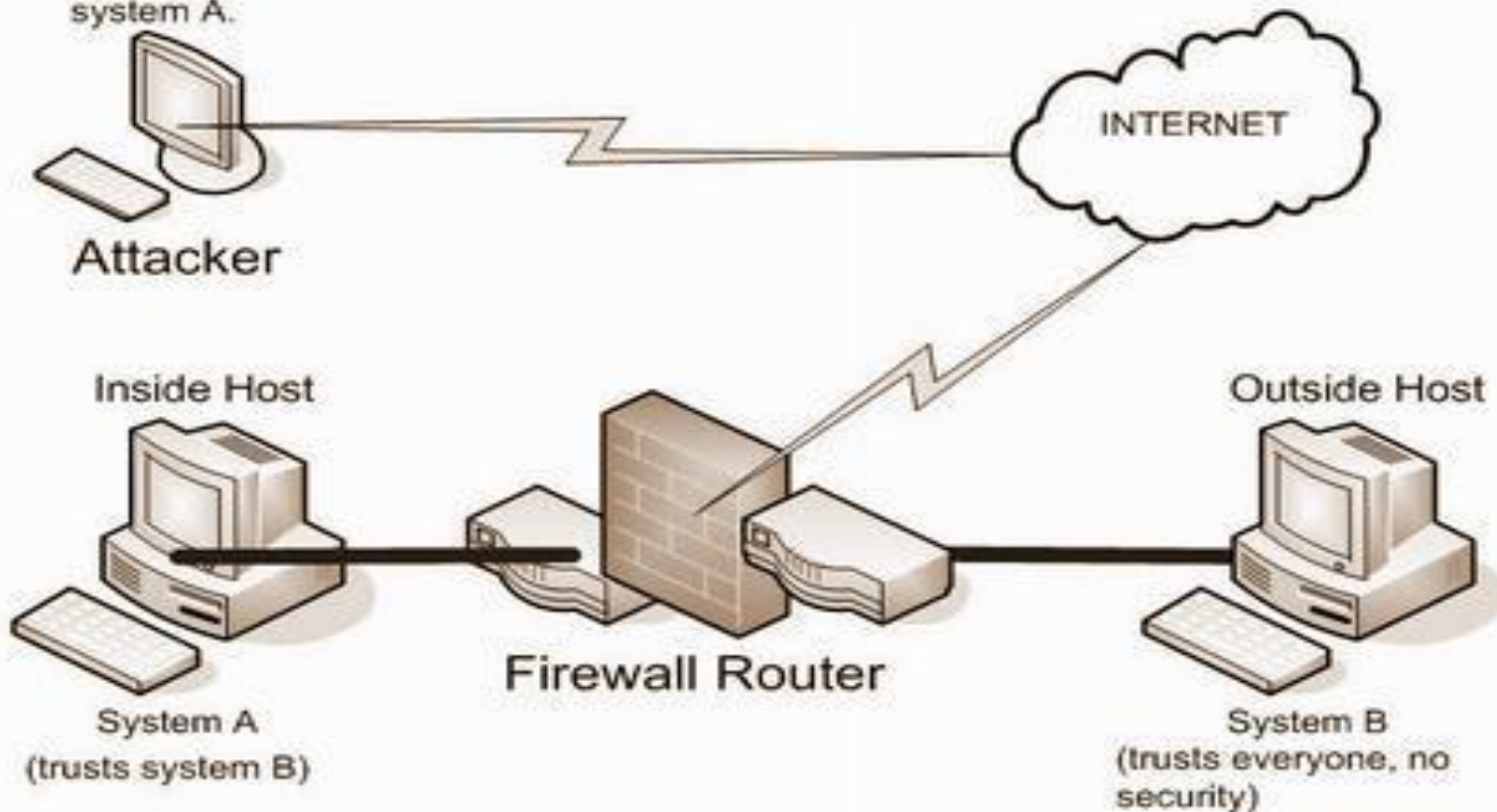
	Dictionary Attack	Brute force Attack	Hybrid Attack
Speed of the Attack	Fast	Slow	Medium
Passwords Cracked	Finds only words	Finds every password(A-Z, 0-9, special characters)	Finds only the password that have a dictionary word as the base

Trust Exploitation

- *Scenario:*
 - When a hacker attacks on a computer which is outside a firewall and that computer has a trust relationship with another computer which is inside the firewall, the hacker can exploit this trust relationship.

Trust Exploitations

If I can gain access to system B, then I will own system A.



Trust Exploitation

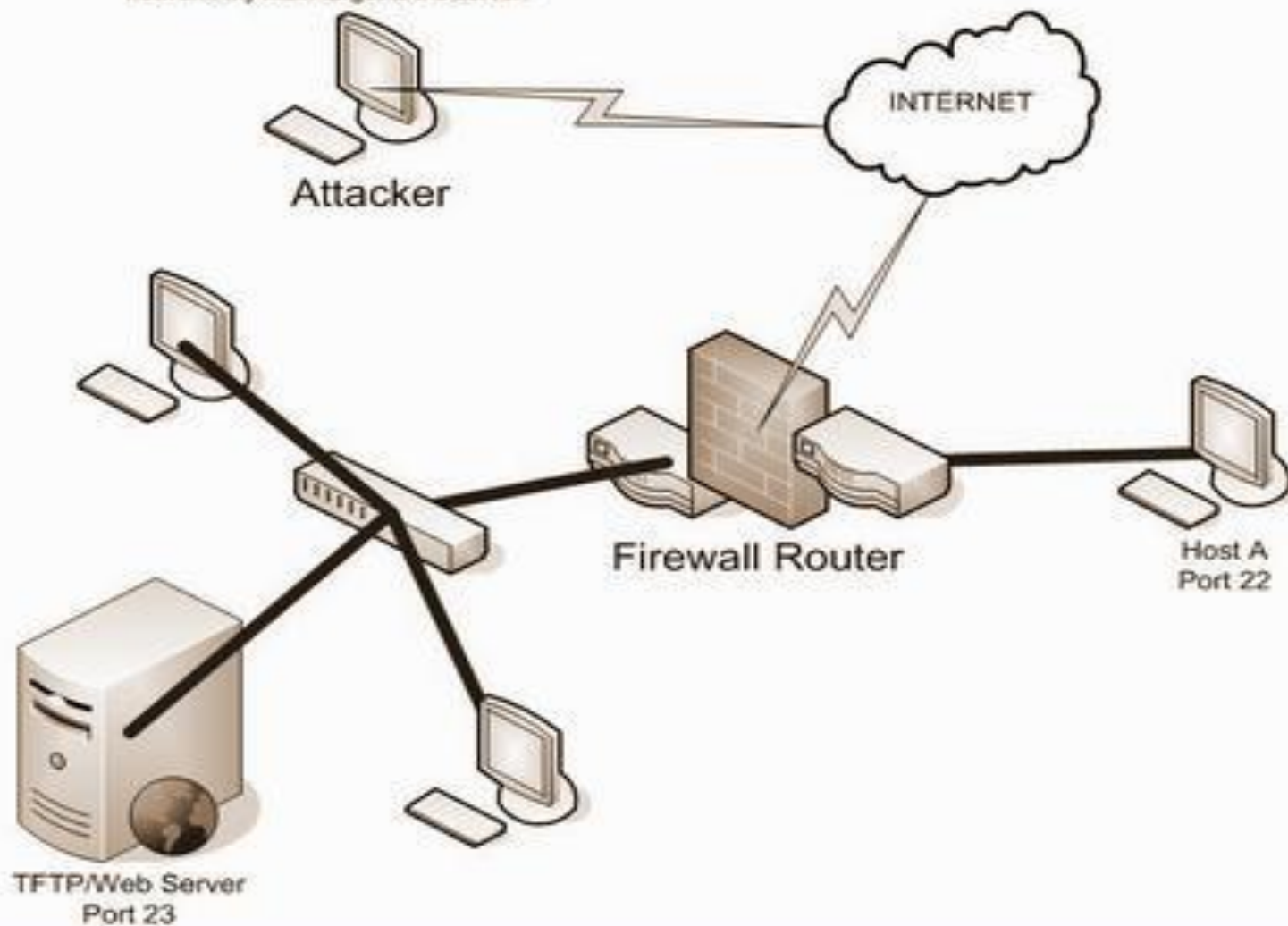
- *Mitigated by:*
 - using private VLANs between switches
 - limiting the trust relationship between systems
 - eliminating useless trust relations between different servers

Port Redirection

- Similar to trust exploitation attack
- The attacker bypasses the security mechanism.
- The attacker installs a software that can redirect the traffic towards the attacker.

Port Redirection

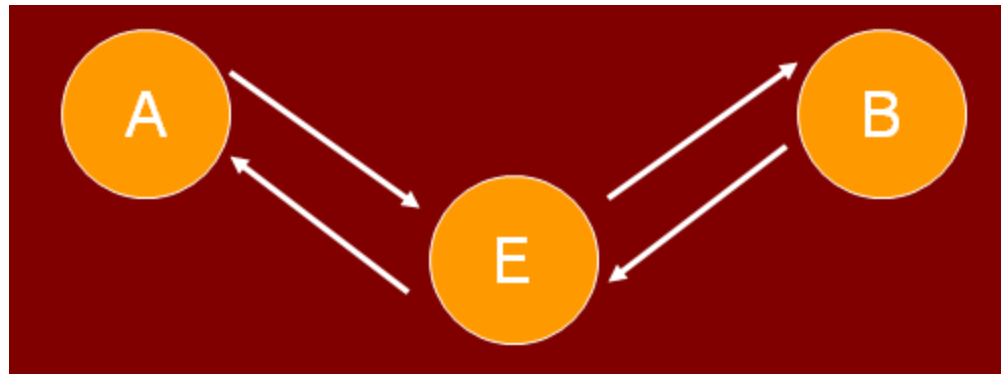
If I can gain access to Host A port 22, then I will install a software to redirect traffic from A into the network. My main target is the server.



Man-in-the-Middle Attack

- The attacker succeed to intrude himself between two communication parties.
- The attacker can
 - **intercept** data between source and destination host
 - **modify** data and retransmit it to the destination host
 - inject any type of false data
- MIM attack can affect on availability, confidentiality, integrity and authenticity of data.

- In a Man-in-the-Middle attack the attacker gets in the middle of a real run of a protocol.



Denial of Service Attack

- An explicit attempt by attackers to prevent legitimate users of a service from using that service.
- The attacker saturated the target machine with useless traffic so that it cannot respond or too slow to respond and some times unavailable.

Major DoS attacks

- In Feb 2000, series of massive DoS attacks incapacitated several e-commerce sites, including **Yahoo, Ebay**
- In Jan 2001, **Microsoft's name sever** infrastructure was disabled
- In Oct 2002, all **Domain Name System servers** were attacked
- In Aug 2009, the attack on **Twitter** and **Facebook**

- Threat:
 - Consumption of network connectivity and/or bandwidth
 - Consumption of other resources, e.g. queue, CPU
 - Destruction or alternation of configuration information
 - Malformed packets confusing an application, cause it to freeze
 - Physical destruction or alternation of network components

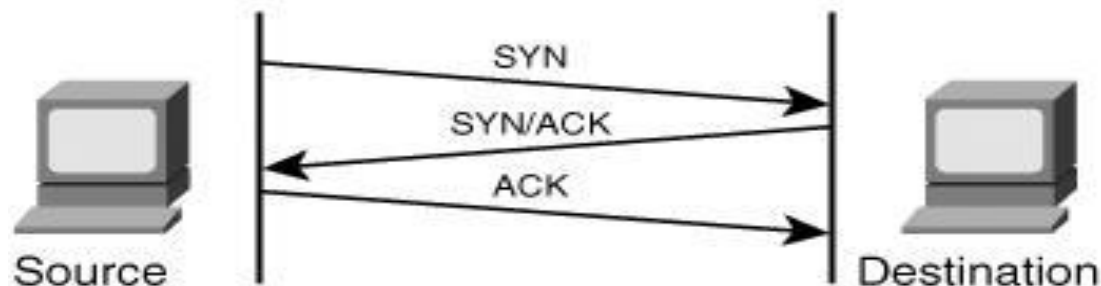
- DoS attacks target:
 - Network bandwidth
 - Flood the network with high volume of traffic
 - Connectivity
 - Flood the victim with high volume of connection requests

Classification of DOS Attacks

Attack	Affected Area	Example	Description
Network Level Device	Routers, IP Switches, Firewalls	Ascend Kill II, "Christmas Tree Packets"	Attack attempts to exhaust hardware resources using multiple duplicate packets or a software bug.
OS Level	Equipment Vendor OS, End-User Equipment.	Ping of Death, ICMP Echo Attacks, Teardrop	Attack takes advantage of the way operating systems implement protocols.
Application Level Attacks	Finger Bomb	Finger Bomb, Windows NT RealServer G2 6.0	Attack a service or machine by using an application attack to exhaust resources.
Data Flood (Amplification, Oscillation, Simple Flooding)	Host computer or network	Smurf Attack (amplifier attack) UDP Echo (oscillation attack)	Attack in which massive quantities of data are sent to a target with the intention of using up bandwidth/processing resources.
Protocol Feature Attacks	Servers, Client PC, DNS Servers	SYN (connection depletion)	Attack in which "bugs" in protocol are utilized to take down network resources. Methods of attack include: IP address spoofing, and corrupting DNS server cache.

SYN flood attack

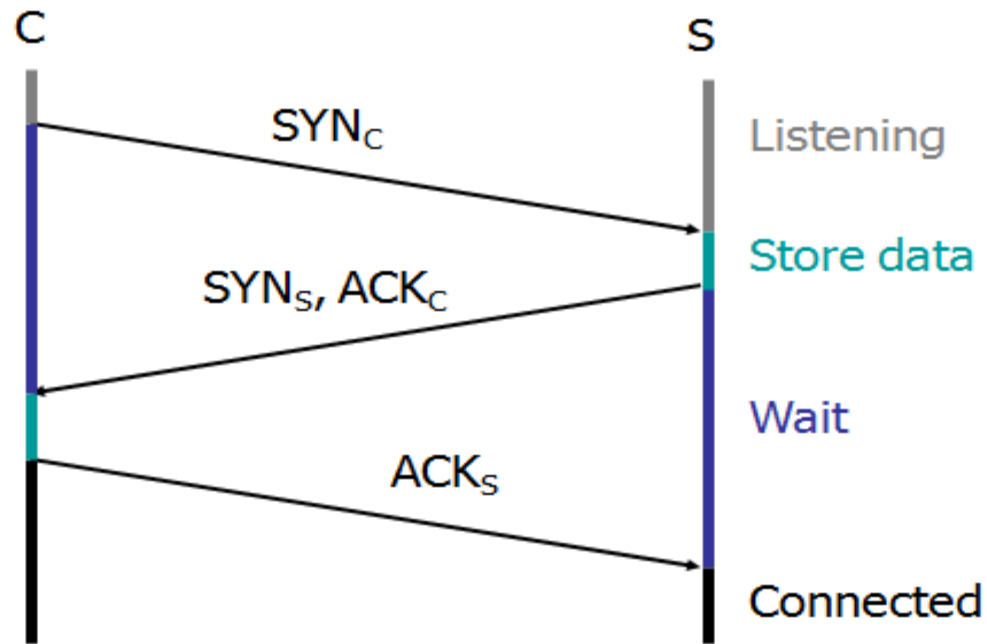
- A SYN flood is one of the oldest and yet still most effective DoS attacks.
- TCP communication begins with a SYN, a SYN-ACK response, and then an ACK response.

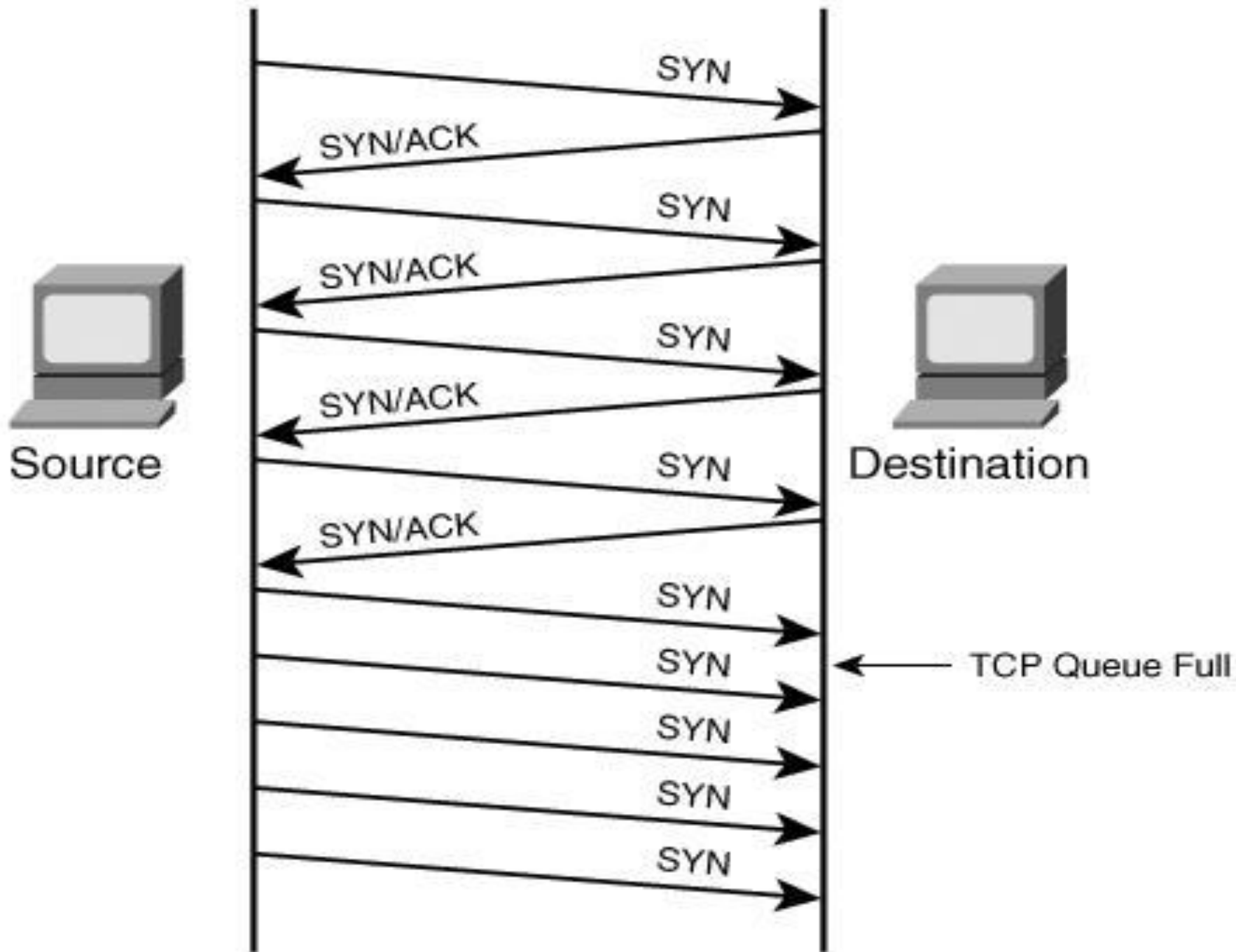


SYN flood attack

- An attacker sends a large number of SYN requests to a target's system
 - Target uses too much memory and CPU resources to process these fake connection requests
 - Target's bandwidth is overwhelmed
- Usually SYN flood packets use spoofed source IPs
- Make the target very hard to decide which TCP SYN is attack and which TCP SYN is from legitimate users

TCP Handshake





ICMP flood attack

- Also known as **Ping Flood Attack**
- An attacker sends a huge number of **ICMP *echo request*** packets to victim.
- The victim cannot respond promptly since the volume of request packets is high and have difficulty in processing all requests and responses rapidly.
- The attack will cause the performance degradation or system down.

Ping of Death Attack

- Ping of Death is an attempt by an attacker to crash, reboot or freeze a system by sending an illegal ICMP packet to the host under attack.
- The TCP/IP specification allows for a maximum packet size of up to 65536 octets.
- In some TCP stack implementation, encountering packets of greater size may cause the victim's host to crash.

TearDrop Attacks

- Teardrop attacks target a vulnerability in the way fragmented IP packets are reassembled.
- Fragmentation is necessary when IP Datagrams are larger than the maximum transmission unit (MTU) of a network segment
- An attacker sends two fragments that cannot be reassembled properly by manipulating the offset value of packet and cause reboot or halt of victim system

Countermeasures for DoS Attacks

Attack	Countermeasure Options	Example	Description
Network Level Device	Software patches, packet filtering	Ingress and Egress Filtering	Software upgrades can fix known bugs and packet filtering can prevent attacking traffic from entering a network.
OS Level	SYN Cookies, drop backlog connections, shorten timeout time	SYN Cookies	Shortening the backlog time and dropping backlog connections will free up resources. SYN cookies proactively prevent attacks.
Application Level Attacks	Intrusion Detection System	GuardDog, other vendors.	Software used to detect illicit activity.
Data Flood (Amplification, Oscillation, Simple Flooding)	Replication and Load Balancing	Akamai/Digital Island provide content distribution.	Extend the volume of content under attack makes it more complicated and harder for attackers to identify services to attack and accomplish complete attacks.
Protocol Feature Attacks	Extend protocols to support security.	ITEF standard for itrace, DNSSEC	Trace source/destination packets by a means other than the IP address (blocks against IP address spoofing). DNSSEC would provide authorization and authentication on DNS information.

Reference

- C Douligeris, A Mitrokosta, *DDoS attacks and defense mechanisms: classification and state of the art*, Computer Network, 44 (2004), 643-666